

1. Sicurezza Informatica e Protocolli di Rete

1. L'uso dell'Access Proxy è indipendente dal protocollo utilizzato?

- L'Access Proxy si differenzia da un proxy normale principalmente per il suo focus sulla sicurezza e sul controllo degli accessi alle risorse. Mentre entrambi i tipi di proxy agiscono come intermediari tra client e server, l'Access Proxy è progettato specificamente per implementare politiche di sicurezza avanzate e gestire l'accesso alle risorse in modo più controllato. E sì, l'uso dell'Access Proxy è generalmente indipendente dal protocollo utilizzato. L'Access Proxy agisce come intermediario tra l'utente e le risorse a cui l'utente sta cercando di accedere, indipendentemente dal protocollo utilizzato per accedere a tali risorse. Il suo ruolo principale è quello di autenticare e autorizzare gli utenti prima di consentire loro l'accesso alle risorse protette. Questo significa che l'Access Proxy può essere configurato per supportare una vasta gamma di protocolli, inclusi HTTP, HTTPS, FTP, SSH e altri ancora. Il protocollo specifico utilizzato per accedere alle risorse non influisce sulle capacità dell'Access Proxy di controllare e proteggere l'accesso alle risorse stesse.

2. Si può fare buffer overflow su un Array Java?

- In Java, il concetto di "buffer overflow" è meno comune rispetto a linguaggi come C o C++, principalmente perché Java gestisce la gestione della memoria in modo molto diverso andando ad utilizzare una zona detta HEAP MEMORY che è una zona di memoria dinamica e contigua che cresce e si riduce automaticamente in base alle esigenze del programma, infatti con il costruttore NEW andiamo ad allocare in modo dinamico una porzione di memoria in JAVA a differenza di C o C++ dove questa operazione deve essere effettuata in modo manuale. Inoltre, Java utilizza un processo all'interno della JVM chiamato Garbage Collector, il quale scansiona periodicamente l'area di memoria per rimuovere memoria occupata da oggetti inutilizzati. Per rispondere alla domanda il buffer overflow vero e proprio non è possibile in Java ma è possibile incorrere in altri errori come **ArrayIndexOutOfBoundsException** che è un errore dovuto al fatto che si sta tentando di accedere ad una zona di memoria fuori dagli array consentiti.

3. Come si possono rilevare virus meta/polimorfici?

- I virus POLIMORFICI sono dei virus creati negli anni 90 con codice completamente crittografato, i virus METAMORFICI sono come i precedenti ma hanno la capacità di mutare completamente il proprio codice. La loro rilevazione è abbastanza difficile proprio per il fatto che mutano nel tempo ma uno dei metodi che si potrebbe utilizzare è quello dell'analisi del comportamento; quindi, ricercare azioni dannose che un programma in esecuzione sta eseguendo come la modifica di file di sistema.

4. Differenza tra le garanzie di sicurezza di SMIME e PGP/GPG

- SMIME E PGP/GPG sono due protocolli utilizzati per garantire la sicurezza delle comunicazioni digitali, in particolare per la posta elettronica. SMIME è uno standard IETF e si basa sul concetto di Certification Authority per la distribuzione e la certificazione delle chiavi pubbliche. PGP/GPG si basa sul concetto di Web of Trust, ovvero legami di fiducia diretti e indiretti stanziati dagli utilizzatori di PGP in questo standard gli utenti possono firmare digitalmente le chiavi pubbliche degli altri utenti per indicare che le ritengono valide.

5. Un attaccante cosa può fare se ho un firewall statico che non può/fa più fatica a fare con firewall dinamico?

- Il firewall è un dispositivo di rete fondamentale per la sicurezza informatica esso si occupa del filtraggio del traffico di rete in base a delle politiche che possiamo impostare in modo statico o in modo dinamico, svolge un ruolo fondamentale nella protezione degli attacchi come scansione delle porte, DoS o DDoS ed inoltre monitora il traffico di passaggio sulla rete. Le differenze principali tra un firewall statico ed uno dinamico risiedono nel fatto che il firewall statico applica delle regole statiche e non può adattarsi in modo dinamico alle nuove minacce provenienti dalla rete, se ad esempio un attacker viene a conoscenza delle regole presenti sul nostro firewall può facilmente aggirarle ed entrare nel sistema senza nessun tipo di problema. Un firewall dinamico ha invece la possibilità di analizzare in modo dinamico il traffico di rete e quindi rispondere in modo più puntuale agli attacchi provenienti dall'esterno, inoltre esso può essere integrato con altre tecnologie di sicurezza come IDS (intrusion detection system).

6. Esempio di attacco contrastabile con Proxy firewall e non con packet filter (e viceversa)?

- Un attacco di tipo Denial of Service (DoS) non sarebbe contrastabile con un Packet Filter Firewall, poiché questo tipo di attacco si basa principalmente su regole di filtraggio di pacchetti che controllano l'accesso basato su IP, porte e protocolli. Se l'attacco proviene da diverse fonti e non supera i limiti imposti sulle connessioni o sulle frequenze, il packet filter potrebbe non rilevarlo come un attacco, il Proxy firewall invece si concentra sul livello applicativo ed agendo da intermediario può rilevare anomalie sul numero di connessioni e sul traffico in arrivo da diverse fonti implementando tecniche di controllo degli accessi proteggerebbe la risorsa sotto attacco. Viceversa, un proxy firewall non potrebbe contrastare una scansione delle porte da parte di un utente malevolo, infatti con il packet filter firewall abbiamo la possibilità di bloccare il traffico in arrivo da una sorgente IP che esegue una scansione delle porte in modo aggressivo.

7. Cos'è un indicatore di compromissione nell'ambito dei sistemi di monitoraggio?

- Gli IoC sono utilizzati per rilevare e identificare attività malevole o anomalie nelle infrastrutture IT e nei dispositivi connessi: Indirizzi IP sospetti, nomi di dominio compromessi, pattern di traffico anomalo ed altri.

Gli IoC fanno parte della famiglia della Threat Intelligence, ovvero i flussi informativi relativi a delle minacce informatiche, questi feedback possono arrivare da vendor di soluzioni di sicurezza, entità esterne che si occupano di sicurezza o altre realtà aziendali con le quali si collabora.

8. In generale cosa si intende per threat intelligence?

- In generale, il termine "threat intelligence" si riferisce alla raccolta, analisi e utilizzo delle informazioni relative alle minacce informatiche al fine di comprendere meglio i rischi per la sicurezza e mitigare le potenziali vulnerabilità nei sistemi informatici e nelle reti.

A livello di threat intelligence abbiamo diversi livelli:

- Operativo: tipicamente trasferite con canali di comunicazione standard e gestiti direttamente dalle macchine come indirizzi IP noti per essere malevoli o IoC che contengono i principali artefatti creati da malware e alcune caratteristiche degli attacchi portati via rete.
- Tattico: Procedure tecnico tattiche di attacchi recenti, non si fa riferimento ad un singolo indirizzo IP o ad un singolo malware ma descrivo le modalità con cui normalmente si comporta un certo attaccante.
- Strategico: di competenza dei manager aziendali.

9. Cosa si intende con attacchi TOCTOU/Race Conditions?

- Gli attacchi TOCTOU ovvero Time-Of-Check to Time-Of-Use si riferiscono al fatto che il sistema controlla lo stato di sicurezza in un certo momento ed in un momento successivo utilizzerà il risultato di questo controllo, il tempo che intercorre tra la verifica fatta e l'utilizzo del risultato risulta essere scoperto e quindi in quel frangente le condizioni possono cambiare senza però generare nessun allarme.
- Le race conditions invece sono degli attacchi che si basano sull'ordine delle istruzioni da eseguire in un programma e l'utilizzo di risorse tra un programma e più programmi concorrenti. Le race conditions possono portare a comportamenti imprevisti o indesiderati, inclusi errori di sincronizzazione, inconsistenze nei dati, corruzione dei dati o violazioni della sicurezza.

10. Cosa c'entra NAT con sicurezza?

- Il NAT (Network Address Translation) svolge un ruolo significativo nella sicurezza informatica fungendo da filtro tra una rete privata e Internet. Tramite il mascheramento degli indirizzi IP interni, impedisce agli attaccanti di individuare direttamente i dispositivi all'interno di una rete, riducendo così il rischio di accessi non autorizzati. Inoltre, limita gli accessi diretti ai dispositivi interni, bloccando i tentativi di connessione non autorizzata. Questa caratteristica contribuisce a proteggere i dispositivi interni da attacchi diretti e intrusioni esterne. Anche se il NAT fornisce un livello iniziale di sicurezza, è essenziale implementare ulteriori misure, ad esempio con un firewall.

11. In un eventuale attacco quale fase va ad impattare? (Intelligence)

- Nel contesto degli attacchi informatici, la fase dell'intelligence gioca un ruolo fondamentale nell'intero ciclo di vita dell'attacco. Questa fase coinvolge la raccolta, l'analisi e l'utilizzo delle informazioni relative al bersaglio, alle sue vulnerabilità e ai suoi punti deboli. Gli attaccanti conducono attività di intelligence per identificare e valutare le potenziali opportunità di attacco, comprendere l'architettura di rete e i sistemi target, e pianificare strategie di attacco efficaci. Durante questa fase, gli attaccanti possono utilizzare diverse fonti di informazioni, come ricerca pubblica, vulnerabilità note, social engineering e altri mezzi per raccogliere dati utili.

12. Come funzionano, in maniera dettagliata, gli attacchi MitM

- Un attacco Man-in-the-Middle (MitM) è un'azione in cui un aggressore si inserisce furtivamente nella comunicazione tra due parti legittime senza che esse ne siano consapevoli. Una volta interposti nella comunicazione, l'attaccante intercetta e cattura il traffico di dati che passa tra le due parti. In alcuni casi, l'attaccante può modificare i dati che passano attraverso la comunicazione. Per eseguire con successo un attacco MitM, l'attaccante deve avere la capacità di intercettare e manipolare il traffico di rete. Questo può essere fatto attraverso varie tecniche, tra cui l'uso di reti Wi-Fi compromesse, l'iniezione di malware sui dispositivi delle vittime, l'utilizzo di ARP spoofing, l'impiego di attacchi DNS spoofing, e altro ancora. È importante notare che l'attacco MitM può essere efficacemente mitigato attraverso l'uso di connessioni sicure crittografate (come HTTPS).

13. Attacco 0-day, ci si può difendere? Un Antivirus può rilevarlo?

- Un attacco "0-day" si riferisce a un attacco che sfrutta una vulnerabilità di sicurezza sconosciuta o non ancora patchata nei sistemi software. Poiché la vulnerabilità è appena stata scoperta o rivelata, non esiste alcuna patch o soluzione nota per correggerla, rendendo gli utenti e i sistemi vulnerabili agli attacchi. Per quanto riguarda la capacità degli antivirus di rilevare gli attacchi 0-day, è importante notare che gli antivirus tradizionali basati su firme potrebbero non essere in grado di rilevare tali minacce, in quanto richiedono una firma specifica per riconoscere il malware. Tuttavia, molti produttori di antivirus stanno integrando tecniche avanzate di rilevamento comportamentale e di analisi delle minacce che possono identificare modelli sospetti o comportamenti anomali.

14. Cos'è e cosa fa un Ransomware? Che tipo di cifratura usa?

- Un ransomware è un tipo di malware progettato per criptare i file o bloccare l'accesso a un sistema, quindi richiedere un pagamento ("ransom") in cambio della decifratura o del ripristino dell'accesso. Il ransomware utilizza un algoritmo di cifratura forte per criptare i file memorizzati sul disco rigido del computer infetto o sulle risorse di rete accessibili. Una volta che i file sono stati criptati con successo, il ransomware mostra un avviso o un messaggio che informa l'utente dell'infezione e delle istruzioni su come pagare il riscatto per ottenere la chiave di decrittazione necessaria per ripristinare i file. Quanto alla cifratura utilizzata dai ransomware, di solito si tratta di *cifratura asimmetrica* (o cifratura a chiave pubblica). In questo tipo di cifratura, due chiavi vengono generate: una chiave pubblica e una chiave privata. La chiave pubblica viene utilizzata per crittografare i file, mentre la chiave privata, che è necessaria per decrittografare i file, è mantenuta segreta dall'autore del ransomware.

15. OTP

- L'OTP si basa sui principi del cifrario monouso, un concetto di crittografia dove ogni password è utilizzata una sola volta, rendendo estremamente difficile per gli attaccanti prevedere la password successiva. Questo livello di sicurezza è fondamentale perché anche se un utente malintenzionato intercetta un OTP, non può essere riutilizzato per l'accesso futuro. Gli OTP vengono generati utilizzando algoritmi crittografici robusti e possono essere generati tramite dispositivi hardware, app mobili o SMS. La loro validità temporanea e la necessità di una connessione sicura contribuiscono a proteggere l'accesso online, mentre l'implementazione di OTP in sistemi a due fattori aumenta ulteriormente la sicurezza.

16. Ciclo di vita di una Vulnerabilità? Come faccio a sapere se ho una vulnerabilità su un software? Dove trovo le informazioni sulle vulnerabilità?

- Le vulnerabilità hanno un ciclo di vita: dopo la morte non sono più utilizzabili. Le vulnerabilità software sono bug particolari contenuti nel codice sorgente. Al rilascio, o all'aggiornamento di un'applicazione, avviene la creazione della vulnerabilità. Nel momento in cui qualcuno si accorge della presenza di una vulnerabilità: cosa succede, dipende da chi la scopre:
 - Nel caso sia scoperto all'interno dell'azienda che ha sviluppato il sw, si procede direttamente con una patch e successivo aggiornamento di risoluzione
 - Nel caso peggiore, viene scoperta da un'attacker, ciò che accade è che l'attacker inizia lo sviluppo di un exploit in grado di sfruttare la vulnerabilità individuata (0-day attack).

Lo sforzo è quello di ridurre il tempo tra la discovery e la patch di soluzione, che porta poi ad una disclosure pubblica della vulnerabilità.

2. Crittografia e Sicurezza dei Dati

1. Cosa è una CA?

- Le Certification Authority nascono dal bisogno di attribuire la chiave pubblica al proprietario della chiave effettiva nello scambio di messaggi per poter garantire l'autenticità del messaggio. Per far ciò si è pensato di ricorrere a delle terze parti fidate così da avere la sicurezza che una certa chiave pubblica appartenga ad una certa entità. Potremmo dire che le CA sono come i notai del web. La CA si occupa quindi di firmare digitalmente la chiave pubblica di Tizio garantendo così a Caio l'effettiva identità di quella chiave.

Il problema però a questo punto potrebbe essere quello dato dall'affidabilità della chiave dell'autorità per questo motivo le CA sono sempre delle aziende molto famose e di rilievo che godono di un'incondizionata affidabilità.

Uno dei certificati più utilizzati è il certificato X.509, i passi per crearlo sono i seguenti:

- L'utente crea una coppia di chiavi (pubblica e privata), firma la propria identità e la chiave pubblica con la sua chiave privata e spedisce il messaggio firmato alla CA.
- La CA verifica informaticamente la firma dell'utente, verifica l'identità dell'utente (a seconda del paese dove ci si trovi), crea un certificato digitale e lo firma. Dopo aver effettuato queste operazioni invia il certificato all'utente che potrà utilizzarlo per comunicare in modo affidabile.

2. Perché un sito mi dà a volte più di un certificato, una certificate chain?

- Un sito web può fornire più di un certificato in una certificate chain per diversi motivi legati alla struttura della Public Key Infrastructure (PKI) e alla necessità di autenticare l'intera catena di certificati. La PKI è organizzata in una gerarchia di certificati, dove i certificati intermedi sono emessi dalle Certificate Authority (CA) e convalidati da CA superiori fino al certificato radice. Il primo certificato nella certificate chain è il certificato del server, che contiene la chiave pubblica del server e le informazioni sull'identità del sito web. certificati intermedi, detti anche certificati di catena, sono emessi dalle CA intermedie e utilizzati per garantire la fiducia nel certificato del server. Questi certificati costituiscono il collegamento tra il certificato del server e il certificato radice della CA.

3. Sicurezza incondizionata/computazionale

- Uno schema di cifratura è detto incondizionatamente sicuro se il testo cifrato generato non contiene abbastanza informazioni per determinare il testo in chiaro, indipendentemente da quanto testo cifrato ho e da quanto tempo si impiega per rompere il cifrario. La sicurezza in pratica si basa su due elementi:
 - Costo per crittoanalizzare il codice supera il valore dell'informazione cifrata
 - Tempo necessario per crittoanalizzare il codice supera il tempo per cui l'informazione contenuta è ritenuta utile.

Se uno dei due criteri di sopra è rispettato, si parla di sicurezza computazionale.

Un esempio di concetto legato alla sicurezza incondizionata è la "sicurezza computazionale" dei sistemi crittografici basati su algoritmi matematici intrinsecamente complessi, come l'algoritmo RSA o il cifrario a chiave simmetrica AES. Questi algoritmi sono progettati per resistere a attacchi computazionali anche molto potenti, rendendo estremamente difficile per un aggressore violare la sicurezza del sistema.

4. Metodo di crittografia DES

- Il DES è un metodo di crittografia che lavora con blocchi di dati di dimensioni fisse (64 bit) e utilizza chiavi di lunghezza specifica (64 bit, di cui solo 56 bit vengono effettivamente utilizzati). Durante il processo di cifratura, il testo in chiaro viene elaborato attraverso una serie di passaggi che coinvolgono sostituzioni (*S-box*) e permutazioni (*P-box*).

Una parte importante del DES è la generazione di sottochiavi, che avvengono tramite un complesso processo di manipolazione della chiave originale.

Nel processo di cifratura DES, i dati in ingresso vengono divisi in due metà di uguale lunghezza e sottoposti a una serie di iterazioni. Durante ogni iterazione, una metà dei dati viene manipolata in base al risultato dell'altra metà, attraverso una combinazione di sostituzioni e permutazioni. Questo processo avviene per un numero prestabilito di cicli, noti come "rounds".

Per quanto riguarda l'algoritmo di decifratura DES, utilizza lo stesso processo di cifratura, ma in ordine inverso. Ciò significa che le sottochiavi vengono applicate in ordine inverso e che le operazioni di sostituzione e permutazione vengono eseguite in modo tale da "srotolare" il processo di cifratura e ripristinare i dati originali.

Uno dei motivi della sua robustezza è dato dal principio di Shannon secondo il quale il cambiamento di un bit in chiaro dovrebbe produrre un cambiamento significativo nel testo

cifrato, DES verifica con successo questa proprietà. Sono stati sviluppati altri algoritmi a partire dal DES come il 3DES il quale raddoppia la complessità dell'algoritmo utilizzando una tecnica a 2 chiavi con encryption-decryption-encryption.

5. Metodo di crittografia AES

- AES (Advanced Encryption Standard) è stato sviluppato in risposta alla necessità di un nuovo algoritmo di crittografia robusto, non segreto e disponibile pubblicamente. Il National Institute of Standards and Technology (NIST) ha lanciato una sfida per sviluppare un algoritmo che potesse essere utilizzato con chiavi di dimensioni diverse, supportando blocchi di 128 bit.

Il funzionamento di AES coinvolge quattro cicli principali:

- Sostituzione dei Byte: Ogni byte del blocco di 128 bit viene sostituito utilizzando una tabella di sostituzione.
- Shift delle Righe: Le righe del blocco vengono spostate in base a uno schema specifico.
- Mescolamento delle Colonne: Le colonne del blocco vengono mescolate per aumentare la confusione dei dati.
- Aggiunta della Sottochiave: Una sottochiave viene aggiunta al blocco corrente tramite un'operazione di XOR.

Ogni passaggio viene ripetuto 9, 11 o 13 volte, a seconda della lunghezza della chiave utilizzata (128, 192 o 256 bit). Questi passaggi aumentano il livello di confusione dei dati durante la crittografia. Durante la fase di decifratura, gli stessi passaggi vengono eseguiti in ordine inverso. Questo processo è progettato in modo che, se si segue l'algoritmo in ordine inverso, si ottiene la decifratura dei dati. L'input per AES è un blocco di 128 bit, rappresentato come una matrice di byte. La chiave di 128 bit viene espansa in un array di parole di 32 bit e utilizzata per generare le sottochiavi necessarie per ciascun ciclo. In sintesi, AES utilizza un approccio iterativo e sistematico per cifrare e decifrare i dati, garantendo un elevato livello di sicurezza e protezione delle informazioni sensibili. La sua struttura e il suo funzionamento lo rendono uno degli algoritmi di crittografia più affidabili e ampiamente utilizzati al mondo.

6. MAC - Message Authentication Code

- Il Message Authentication Code (MAC) è un codice crittografico che viene generato applicando un algoritmo crittografico a un messaggio usando una chiave segreta condivisa tra mittente e destinatario. Questo codice fornisce un'impronta digitale del messaggio, che viene inviata insieme al messaggio stesso. Il destinatario può quindi calcolare lo stesso codice utilizzando la stessa chiave e l'algoritmo e confrontarlo con il codice ricevuto. Se i due codici corrispondono, il destinatario può essere sicuro che il messaggio non è stato alterato e proviene da una fonte autenticata. Il MAC fornisce un meccanismo di verifica dell'integrità e dell'autenticità dei dati che viaggiano su una rete non sicura, essenziale per garantire la sicurezza delle comunicazioni.

7. Proprietà digest/hash

- L'obiettivo dell'algoritmo di digest è quello di creare un riassunto univoco e di lunghezza fissa dei dati del messaggio, consentendo al mittente e al destinatario di verificare l'integrità dei dati trasferiti. Se i digest sono uguali, la comunicazione è avvenuta con successo, senza intercettazione. Se sono diversi, vuol dire che nella trasmissione c'è stata una modifica del messaggio (violazione integrità). Per ottenere un digest del messaggio di lunghezza fissata, si utilizza una funzione hash h , che ha come input il messaggio m (lunghezza arbitraria), con determinate proprietà:
 - La funzione hash deve avere una bassa complessità computazionale nel calcolo del digest di un messaggio.
 - Non Invertibilità: La funzione h deve essere unidirezionale: Dato y deve essere impossibile trovare un messaggio m tale che $h(m) = y$.
 - Dato m deve essere impossibile trovare un messaggio m' diverso da m tale che $h(m)=h(m')$.
 - La funzione h deve essere fortemente resistente alle collisioni Deve essere impossibile trovare due messaggi m_1 m_2 diversi tali che abbiano lo stesso valore di hash.
 - La funzione hash deve distribuire i digest in modo uniforme per ogni messaggio m .

Poiché una funzione hash non utilizza una chiave, nel caso di digest mittente e destinatario siano uguali, abbiamo la sola garanzia che il messaggio NON è stato alterato durante la trasmissione.

SHA, acronimo di Secure Hash Algorithm, è una famiglia di funzioni di hash crittografiche sviluppata dal National Institute of Standards and Technology (NIST) degli Stati Uniti. Queste funzioni di hash sono progettate per produrre un valore di hash univoco e irripetibile per un dato input. SHA-2 è un algoritmo con diverse varianti, ogni variante fornisce un hash con una lunghezza specifica: 224, 256, 384 o 512 bit. SHA-256 è il più comune tra questi e viene utilizzato ampiamente per la crittografia e la sicurezza su Internet.

8. Problemi delle chiavi asimmetriche

- Le chiavi asimmetriche, o crittografia a chiave pubblica, costituiscono un sistema crittografico che coinvolge coppie di chiavi matematicamente correlate: una chiave pubblica e una chiave privata. La chiave pubblica è distribuita liberamente e utilizzata per cifrare i dati o verificare le firme digitali, mentre la chiave privata è mantenuta segreta dall'utente e utilizzata per decifrare i dati cifrati o generare firme digitali. Questo sistema è ampiamente usato per crittografare dati sensibili, autenticare mittenti e garantire l'integrità delle informazioni senza la necessità di scambiare segreti condivisi.

Le chiavi asimmetriche hanno il vantaggio di essere sicure perché la chiave privata rimane segreta, elimina la necessità di scambiare delle chiavi prima della comunicazione e forniscono un modo sicuro per autenticare l'identità e garantire l'integrità dei dati.

Gli svantaggi sono dati dal fatto che richiedono una complessità computazionale maggiore rispetto a quelli simmetrici, vi deve essere comunque una gestione sicura per le chiavi ed inoltre le chiavi asimmetriche tendono ad avere delle dimensioni maggiori rispetto alle chiavi simmetriche influenzando la trasmissione dei dati.

9. Certificate pinning

- Il certificate pinning è una tecnica di sicurezza utilizzata per rafforzare la connessione HTTPS tra un client (come un'applicazione mobile o un browser) e un server. In sostanza, il pinning dei certificati consente al client di accettare solo determinati certificati o autorità di certificazione come validi per stabilire una connessione sicura con il server. Quando il client tenta di stabilire una connessione con il server, verifica che il certificato presentato dal server corrisponda esattamente ai certificati fidati preconfigurati. Se non c'è corrispondenza, la connessione viene rifiutata.

10. Come funziona la firma digitale di un documento?

- Quando un autore desidera firmare digitalmente un documento, crea una sorta di impronta digitale unica del documento stesso. Questa impronta digitale viene generata utilizzando una chiave segreta personale, chiamata *chiave privata*. Utilizzando questa chiave privata, l'autore crittografa l'impronta digitale, creando così la firma digitale del documento. La firma digitale è quindi inviata insieme al documento stesso. Chi riceve il documento può verificare la firma digitale utilizzando una chiave pubblica associata alla chiave privata dell'autore. Questa chiave pubblica è in grado di decifrare la firma digitale, rivelando così l'impronta digitale originale del documento. Se l'impronta digitale originale e quella decifrata corrispondono, significa che il documento non è stato alterato e che proviene dall'autore corretto. Questo processo garantisce che il documento sia autentico, integro e che l'autore non possa negare di averlo firmato.

11. Hashing

- L'Hashing è un processo matematico che prende un input di dati di qualsiasi dimensione e restituisce un output di lunghezza fissa, chiamato hash. Questo hash è essenzialmente una "firma digitale" univoca dei dati in ingresso. L'algoritmo di hash elabora i dati in ingresso utilizzando una serie di calcoli matematici complessi per produrre l'hash, che è una stringa di lunghezza fissa, solitamente espressa in formato esadecimale. Due insiemi di dati diversi non devono mai generare lo stesso hash. Anche una piccola modifica nei dati di ingresso dovrebbe generare un hash completamente diverso. Una volta che i dati sono stati hashati, non è possibile recuperare i dati originali.

Alcuni dei metodi più utilizzati per hashare dei dati sono SHA-256 e MD5.

12. Supponi di avere un'azienda con sedi distribuite geograficamente, come fai a mettere in sicurezza le comunicazioni tra le due?

- Per mettere in sicurezza la comunicazione tra due reti distribuite geograficamente utilizzerai un tunnel VPN point-to-point, una VPN crea un tunnel crittografato attraverso Internet, consentendo alle sedi geograficamente distribuite di connettersi in modo sicuro come se fossero sulla stessa rete locale. Utilizza protocolli di crittografia per proteggere i dati durante il transito, garantendo che le comunicazioni siano al riparo da intercettazioni. Le VPN possono essere configurate per supportare vari tipi di tunneling, come IPsec, SSL/TLS. IPsec (Internet Protocol Security): IPsec è un insieme di protocolli e standard utilizzati per garantire la sicurezza delle comunicazioni IP su una rete.

Funziona a livello di rete (Livello 3 del modello OSI), il che significa che protegge il traffico IP trasportato attraverso la rete. IPsec offre due principali modalità di funzionamento: la modalità Transport, che crittografa solo i dati del pacchetto IP, e la modalità Tunnel, che crittografa l'intero pacchetto IP.

Utilizza protocolli crittografici come ESP (Encapsulating Security Payload) e AH (Authentication Header) per fornire autenticazione, integrità dei dati e confidenzialità del traffico IP. IPsec è ampiamente utilizzato per implementare VPN site-to-site e VPN remote access, consentendo a dispositivi e reti di comunicare in modo sicuro su Internet.

SSL/TLS (Secure Sockets Layer/Transport Layer Security), sono protocolli crittografici utilizzati per garantire la sicurezza delle comunicazioni su Internet, in particolare nelle comunicazioni via web. SSL è il predecessore di TLS, ma entrambi i protocolli sono ampiamente utilizzati per creare connessioni sicure tra client e server su Internet. SSL/TLS opera a livello di trasporto (Livello 4 del modello OSI), fornendo un canale sicuro di comunicazione tra due entità. SSL/TLS utilizza crittografia asimmetrica per stabilire una chiave di sessione condivisa segreta tra client e server, che viene utilizzata per crittografare e proteggere i dati trasmessi durante la sessione. Il protocollo SSL/TLS include fasi di negoziazione della sicurezza, autenticazione delle parti, scambio delle chiavi, crittografia dei dati e verifica dell'integrità dei messaggi.

13. Cosa potrebbe usare uno sviluppatore per gestire, memorizzare i dati relativi a password di un'applicazione utente?

- Uno sviluppatore potrebbe utilizzare delle funzioni di hash. Un utilizzo molto comune delle funzioni di hash è quello di applicarle per la memorizzazione delle password su file. Quando un utente effettua il login, e inserisce la password, il sistema calcola l'hash della password e confronta se è uguale a quello memorizzato.

3. Sicurezza delle Reti e dei Sistemi

1. Posso avere qualcosa di utile anche senza iniettare una Shellcode? Se non la metto cosa ci posso mettere? (Eseguire altri comandi e.g.)

- L'iniezione di shellcode è una tecnica utilizzata principalmente nell'ambito delle vulnerabilità di sicurezza e degli exploit, dove un attaccante cerca di inserire e eseguire codice malevolo all'interno di un programma o di un sistema per ottenere accesso non autorizzato o per compiere altre azioni dannose. Si potrebbero utilizzare in alternativa dei comandi per eseguire dei comandi specifici per la manipolazione di file e directory, ad esempio si potrebbero utilizzare comandi come ls, cat, rm, mkdir ecc...

2. Cos'è il rischio e come faccio a valutarlo? Come faccio risk treatment?

- Il rischio, in termini di sicurezza informatica, è la probabilità di subire danni o perdite a causa di minacce o vulnerabilità. Valutare il rischio implica analizzare quanto una minaccia potenziale potrebbe sfruttare le vulnerabilità presenti nei sistemi o nei processi. Il primo passo è quello dell'Identificazione del Rischio, quindi identificare le possibili minacce ed identificare le vulnerabilità nei sistemi. Si passa poi alla Valutazione del rischio, quindi stimare la probabilità di occorrenza della minaccia, valutare l'impatto potenziale, la terza fase è quella del calcolo del rischio ed utilizzare modelli matematici o metodologie qualitative per calcolare il rischio complessivo.

- Il **Risk Treatment** una volta identificato e valutato il rischio, è necessario decidere come gestirlo, come:
 - Mitigazione, ridurre la probabilità di occorrenza o l'impatto di una minaccia attraverso controlli e misure preventive.
 - Accettazione, accettare il rischio senza implementare misure di mitigazione, può essere una scelta strategica quando il costo della protezione supera il possibile danno.
 - Trasferimento, trasferire il rischio a terzi, ad esempio l'acquisto di assicurazioni o l'outsourcing di determinate attività.
 - Evitamento, evitare completamente le attività o le tecnologie che presentano un rischio elevato.
 - Monitoraggio continuo, implementare un processo di monitoraggio costante per adattarsi ai cambiamenti nelle minacce e della vulnerabilità.

3. Supponi di essere un gestore di sito web, ad un certo punto ricevi un DDoS, come ti difendi?

- Se un gestore di un sito web si trova ad affrontare un attacco DDoS (Distributed Denial of Service), può adottare diverse strategie per difendersi e mitigare l'impatto dell'attacco. Ecco alcuni approcci comuni:
 - *Utilizzo di un servizio di mitigazione DDoS:* Molte aziende offrono servizi di mitigazione DDoS che possono aiutare a proteggere il sito web. Questi servizi possono rilevare e filtrare il traffico dannoso prima che raggiunga il server del sito web.
 - *Configurazione di filtri e firewall:* È possibile configurare filtri e firewall per bloccare il traffico sospetto o dannoso. Questo può includere l'identificazione e il blocco degli indirizzi IP sorgente noti per essere utilizzati per attacchi DDoS.
 - *Aumento delle risorse del server:* Aumentare le risorse del server, come larghezza di banda, capacità di elaborazione e memoria, può aiutare il sito web a sopportare meglio gli attacchi DDoS.
 - *Utilizzo di servizi di caching e CDN:* Utilizzare servizi di caching e CDN (Content Delivery Network) può distribuire il carico di lavoro e aiutare a ridurre l'impatto degli attacchi DDoS sul server principale.

4. Cosa può fare un ISP in caso di attacco DDoS?

- Gli Internet Service Provider (ISP) possono adottare diverse misure per affrontare e mitigare gli attacchi DDoS (Distributed Denial of Service) che interessano i propri clienti o la loro infrastruttura. Gli ISP possono implementare filtri per identificare e bloccare il traffico dannoso che costituisce un attacco DDoS. In alcuni casi, gli ISP possono redirezionare il traffico proveniente da indirizzi IP sospetti o dannosi verso infrastrutture di mitigazione o "scrubbing centers" in grado di filtrare il traffico dannoso prima che raggiunga il destinatario finale. Gli ISP possono aumentare la capacità della propria rete per gestire meglio il traffico durante gli attacchi DDoS e limitare l'impatto sull'infrastruttura e sui clienti.

4. Tecnologie e Protocolli di Sicurezza

1. Cos'è una VPN? E quali sono le sue garanzie di sicurezza? Cosa è meglio per realizzarla, IPsec o SSL? Ci sono casi d'uso in cui è preferibile IPsec a SSL?

- Una VPN, acronimo di Virtual Private Network, è una rete privata virtuale che consente a utenti remoti di connettersi in modo sicuro a una rete aziendale o a una rete privata su Internet attraverso una connessione crittografata. Le garanzie di sicurezza offerte da una VPN includono la crittografia dei dati che tutti i dati scambiati tra il dispositivo dell'utente e il server VPN sono crittografati, rendendo difficile per gli aggressori intercettare o manipolare il traffico.

Per quanto riguarda la scelta tra IPsec e SSL per implementare una VPN, entrambi hanno vantaggi e sono adatti a diversi scenari:

- *IPsec (Internet Protocol Security)*: IPsec opera a livello di rete e offre un'ampia gamma di funzionalità di sicurezza, tra cui crittografia, autenticazione e integrità dei dati. È spesso preferito per le reti aziendali, in quanto può essere utilizzato per stabilire connessioni sicure tra sedi distanti e consente un controllo più granulare sulle politiche di sicurezza.
- *SSL (Secure Sockets Layer) / TLS (Transport Layer Security)*: SSL/TLS operano a livello di trasporto e sono spesso utilizzati per consentire connessioni sicure tra dispositivi client e server tramite browser Web. Le VPN SSL sono più facili da implementare e possono essere utilizzate per fornire accesso remoto sicuro a risorse aziendali per utenti mobili o remoti.

2. A cosa servono a un attaccante le operazioni di fingerprinting, scansione ecc? Materialmente come faccio a fare una scansione?

- Le operazioni di fingerprinting e scansione sono fondamentali per un attaccante poiché forniscono informazioni dettagliate sulla configurazione, sulle vulnerabilità e sulle caratteristiche di una rete o di un sistema.
- *Fingerprinting*: Questa tecnica consente all'attaccante di identificare i servizi, i sistemi operativi, le versioni del software e altre informazioni rilevanti su una particolare risorsa di rete. Queste informazioni possono essere utilizzate per pianificare e lanciare attacchi mirati, in quanto consentono di individuare le vulnerabilità specifiche associate a un determinato ambiente.
- *Scansione di porte*: La scansione delle porte permette all'attaccante di determinare quali porte di rete sono aperte, chiuse o filtrate su un determinato sistema. Questo fornisce informazioni sulla topologia della rete e sugli eventuali servizi o protocolli in esecuzione su di essa, che possono essere sfruttati per effettuare intrusioni.
- *Scansione di vulnerabilità*: Questa operazione mira a identificare le vulnerabilità presenti nei sistemi o nelle applicazioni in esecuzione su una rete. Gli attaccanti utilizzano strumenti automatici o manuali per individuare punti deboli che possono essere sfruttati per ottenere accesso non autorizzato o causare danni.

3. Parla di TLS

- TLS, acronimo di Transport Layer Security, è un protocollo crittografico utilizzato per garantire la sicurezza delle comunicazioni su Internet. È il successore del protocollo SSL (Secure Sockets Layer) e fornisce un livello aggiuntivo di sicurezza durante lo scambio di dati tra client e server su una rete.

Il protocollo TLS esegue i seguenti passi:

- *Handshake TLS:* Il processo inizia con un handshake TLS, durante il quale il client e il server stabiliscono una connessione sicura. Il client invia un messaggio di "client hello" contenente le sue preferenze di crittografia e altre informazioni al server. Il server risponde con un messaggio di "server hello", che include la scelta dell'algoritmo di crittografia e il certificato digitale del server. Il client verifica il certificato del server per garantire che sia valido e attendibile, quindi genera una chiave di sessione segreta utilizzata per crittografare i dati durante la sessione. Il client invia un messaggio di "finished" per confermare che il suo scambio di chiavi è completo. Il server verifica la chiave di sessione del client e invia un messaggio "finished" confermando che è pronto a iniziare la comunicazione sicura.
- *Integrità dei dati:* Durante la trasmissione, TLS include anche meccanismi per garantire l'integrità dei dati. Viene utilizzata una funzione di hash crittografica per calcolare un valore hash dei dati trasmessi, che viene quindi inviato insieme ai dati. Il destinatario può verificare l'integrità dei dati calcolando nuovamente il valore hash e confrontandolo con quello ricevuto. Se i valori corrispondono, i dati sono stati trasferiti senza alterazioni.
- *Chiusura della connessione:* Quando la comunicazione è completata, il client e il server possono chiudere la connessione TLS. Vengono scambiati messaggi di chiusura per notificare l'intenzione di terminare la sessione in modo ordinato e sicuro.

4. HTTPS

- HTTPS, acronimo di Hypertext Transfer Protocol Secure, è una versione sicura del protocollo HTTP utilizzata per la comunicazione sicura tra client e server su Internet. È stato scelto al posto di HTTP perché offre numerosi vantaggi in termini di sicurezza e protezione dei dati.

Il suo funzionamento si basa sulla:

- *Crittografia dei dati:* HTTPS utilizza il protocollo TLS (Transport Layer Security) o il suo predecessore SSL (Secure Sockets Layer) per crittografare i dati scambiati tra il client e il server. Questo significa che tutti i dati trasmessi sono protetti da intercettazioni non autorizzate durante il trasferimento, garantendo la privacy e la sicurezza delle informazioni sensibili, come le password e i dettagli delle carte di credito.
- *Autenticazione del server:* Con HTTPS, il server invia al client un certificato digitale che contiene informazioni sulla sua identità e la chiave pubblica necessaria per stabilire una connessione sicura. Il client può verificare l'autenticità del certificato del server per assicurarsi di essere connesso al server corretto e non a un server malevolo o contraffatto.

5. Usando la chiave pubblica del server si può impersonare?

- No, non è possibile impersonare il server utilizzando la sua chiave pubblica. La chiave pubblica del server viene utilizzata principalmente per due scopi:
 - Crittografia dei dati: La chiave pubblica del server viene utilizzata per crittografare i dati inviati dal client al server durante la fase di handshake TLS/SSL. Solo il server, che possiede la chiave privata corrispondente, può decrittografare questi dati una volta ricevuti.
 - Verifica dell'autenticità del server: Il certificato digitale del server, che include la sua chiave pubblica, viene inviato al client durante l'inizio della connessione TLS/SSL. Il client utilizza la chiave pubblica per verificare l'autenticità del certificato e quindi del server. Se il certificato è valido e può essere autenticato, il client può essere sicuro che sta comunicando con il server desiderato e non con un'entità malevola.

Poiché la chiave pubblica del server viene utilizzata solo per crittografare i dati e per verificare l'autenticità del server, non è possibile impersonare il server utilizzando la sua chiave pubblica. Per impersonare un server, un attaccante dovrebbe avere accesso alla chiave privata corrispondente al certificato del server, il che è estremamente difficile e dovrebbe essere impossibile in un ambiente di sicurezza ben configurato.

6. Quali sono le tre azioni per mettere in sicurezza un sistema?

- Segregazione/Segmentazione: sono due concetti fondamentali sulla sicurezza delle reti locali, la *segmentazione* si occupa del partizionamento delle risorse aziendali sia logiche che fisiche oltre a dividere la rete in sottoreti. La *segregazione* definisce le politiche per accessi cross-segment, ovvero isolare un ambiente di rete.
- Un'altra azione da intraprendere è quella delle creazioni di una VLAN, mediante questa tecnologia gli host possono essere raggruppati "logicamente" in base alla funzione che svolgono, tecnicamente la creazione di una VLAN equivale alla creazione di un dominio di broadcast al quale interno gli host possono comunicare liberamente e al cui esterno tali host devono passare per un router. Le VLAN non nascono propriamente per soddisfare requisiti di sicurezza ma il loro utilizzo permette la creazione di piccoli segmenti di rete più semplici da gestire.
- Un'altra azione da intraprendere è l'aggiunta di un firewall alla rete, tale dispositivo si interpone tra la rete locale ed una rete esterna. Il firewall è utile quindi per dividere due segmenti di rete che hanno livelli di sicurezza differenti, è sbagliato pensare che il firewall sia solamente un elemento perimetrale poiché esso può essere utilizzato anche all'interno di una stessa rete. Il principio del firewall si basa sul fatto che esso è l'unico punto di contatto fra due reti diverse ed è lui a decidere, a seconda delle policy impostate, quale traffico può passare e quale no.

7. Parlatemi della segregazione e segmentazione con riferimento al lateral movement

- La segregazione e la segmentazione sono due tecniche che permettono di dividere e isolare una parte della rete andando così da creare degli ambienti più e di più facile gestione/controllo. Il lateral movement è quella tecnica utilizzata da un utente malevolo che gli permette di passare da un dominio compromesso ad un altro, utilizzando delle tecniche di segmentazione/segregazione è possibile mitigare questo effetto rendendo gli ambienti più isolati.

8. Come mai anche in presenza di segmentazione/segregazione alcune aziende vengono violate?

- La tecnica della segregazione/segmentazione non è sinonimo di inviolabilità, con tale tecnica possiamo limitare i danni in caso di attacco ma se non ben strutturata e quindi vi sono dei “buchi” nella rete per permettere ad esempio la condivisione di file tra due reti diverse renderebbe inutile il lavoro di tali tecniche.

9. Che cosa sono e perché raccogliamo i LOG?

- I LOG sono registrazioni dettagliate di eventi che si verificano all'interno di un sistema, come un'applicazione, un server o una rete. Questi eventi possono includere azioni degli utenti, transazioni di rete, errori del sistema, attività di sicurezza e molto altro. A livello di sicurezza potrebbero essere di particolare interesse tutti i LOG che si riferiscono alla gestione degli accessi come i log APM, ovvero quelli che si riferiscono alle Access Policy Manager.

10. Cosa è un next gen firewall?

- Per next gen firewall si intende quella famiglia di firewall che si promette di essere un dispositivo tutto in uno quindi di fare Packet Filtering, VPN, Web Application Firewall, Intrusion Detection System. Possiamo dire che è una buzzword prettamente commerciale poiché in realtà se tale firewall viene utilizzato in modo proprio con la creazione di tutte le regole le sue prestazioni sarebbero così scarse da renderlo inutilizzabile.

11. Cos'è una funzione di HASHING e come funziona?

- Una funzione di hashing è una funzione per la quale dato in ingresso una stringa di lunghezza variabile ritornerà una stringa di lunghezza fissa viene utilizzata in vari ambiti della sicurezza informatica in particolare nella protezione di password all'interno di database poiché permette di rendere le password crittografate. Una funzione di hash deve soddisfare diverse proprietà, la più importante è quella del senso unico ovvero che deve essere impossibile a risalire al testo in chiaro una volta che esso è stato trasformato.

Inoltre, un buon algoritmo di hash deve essere a prova di collisione, ovvero non deve accadere che con diversi dati di origine venga creata la stessa chiave di hash, inoltre deve rispettare anche dei criteri di tempo poiché la sua creazione non deve essere computazionalmente onerosa e lunga.

Oltre che per la gestione di password (SHA256) l'hashing viene largamente utilizzato anche nel trasferimento di dati cifrati mediante SSL.

12. Come funziona e cosa è la cifratura a flusso, quando è utile? Lati positivi e lati negativi?

- La cifratura a flusso è una tecnica di cifratura che lavora su flussi di dati piuttosto che su blocchi discreti di dati come nella cifratura a blocchi. Funziona generando un flusso di bit pseudocasuali, noto come chiave di flusso, che viene combinato bit per bit con i dati in chiaro per produrre dati cifrati. La chiave di flusso deve essere generata sia dal mittente che dal destinatario in modo sincronizzato.

Per poter funzionare in modo proprio destinatario e mittente della comunicazione devono possedere le stesse chiavi per poter effettuare correttamente la cifratura, la chiave di flusso viene combinata bit per bit con il flusso di dati attraverso un'operazione XOR, alla fine il destinatario utilizzerà la chiave di flusso a sua disposizione per decifrare il messaggio.

Anche se a livello computazionale la cifratura a flusso risulta essere migliore della cifratura a blocchi nasconde dei problemi intrinseci che non sono facilmente risolvibili come la gestione delle chiavi dato che mittente e destinatario devono utilizzare la stessa chiave privata ed inoltre tale cifratura non garantisce l'integrità dei dati perché vi potrebbe essere un soggetto terzo all'interno della trasmissione che è in possesso delle chiavi e non potrebbe essere rilevabile.

13. Come vengono distribuite le chiavi?

- Il problema della distribuzione delle chiavi è il punto più negativo della crittografia simmetrica, idealmente il metodo migliore per la distribuzione delle chiavi è quello della consegna manuale così si è sicuri che la consegna è stata effettuata in modo corretto.

In molti casi la protezione crittografica è stata superata non a causa di un cattivo algoritmo, ma a causa di una cattiva scelta della chiave e/o di una cattiva gestione e protezione della chiave da parte di uno degli interlocutori.

14. Algoritmi di cifratura a chiave pubblica, come funzionano ed uno esempio?

- Gli algoritmi di cifratura a chiave pubblica fanno parte della famiglia della crittografia asimmetrica:

Ogni utente è dotato di una coppia di chiavi complementari:

- Public Key: conosciuta da tutti, usata solo per cifrare il messaggio.
- Private Key: tenuta al sicuro dal proprietario utilizzata solamente per decifrare.

L'algoritmo di Diffie-Hellman è stato uno dei primi ad utilizzare questa tecnologia, le parti coinvolte concordano su dei parametri pubblici tra cui un numero primo grande P ed un numero generatore G che è una primitiva di p .

A questo punto i due utenti generano una chiave privata, un numero casuale scelto in un intervallo predefinito. A questo punto attraverso dei calcoli matematici viene calcolata la chiave pubblica, gli utenti si scambieranno le chiavi ed utilizzando le chiavi pubbliche ricevute e la propria chiave privata, entrambe le parti calcolano la stessa chiave segreta. La chiave segreta S ottenuta da entrambe le parti sarà la stessa, e può essere utilizzata per crittografare e decrittografare le comunicazioni tra di loro.

Uno degli algoritmi più conosciuti con crittografia a chiave asimmetrica è RSA e si basa sulla difficoltà di fattorizzare grandi numeri primi.

15. VLAN come sono fatte? E per cosa le utilizzo?

- Le VLAN sono dei segmenti di rete virtuale che vengono utilizzati per dividere logicamente dei segmenti della rete fisica. Vengono utilizzate principalmente per dividere diversi contesti logici all'interno di una stessa organizzazione potremmo pensare ad esempio ai vari dipartimenti afferenti ad una stessa università, il loro scopo può essere legato anche alla sicurezza andando ad isolare degli ambienti virtuali in modo che i vari domini non siano direttamente collegati fra loro.

16. Cos'è il frame tagging all'interno di una VLAN? E quando viene utilizzato?

- Il "frame tagging" all'interno di una VLAN si riferisce alla pratica di aggiungere un'etichetta (tag) a livello di frame Ethernet per identificare a quale VLAN il frame appartiene. Questo tagging consente ai dispositivi di rete di instradare correttamente i frame attraverso la rete virtuale. Viene principalmente utilizzato nei collegamenti tra switch o tra switch e router, dove è necessario trasportare il traffico di più VLAN attraverso un singolo collegamento fisico.

17. Che protocollo viene utilizzato a livello di rete LAN per il trasporto dei pacchetti?

- Ethernet. Esso viene utilizzato come tecnologia di rete a livello di collegamento dati, ed è utilizzata per trasmettere dati all'interno di una rete locale (LAN). Il frame tagging, d'altra parte, è una tecnica utilizzata per contrassegnare i frame Ethernet con informazioni aggiuntive, come l'identificatore di VLAN (Virtual LAN), per consentire la suddivisione del traffico in diverse VLAN su una rete comune.

18. Quali sono le proprietà che si vogliono garantire in una comunicazione sicura?

- Le proprietà più importanti che vogliamo garantire all'interno di un contesto di comunicazione sicura sono le seguenti:
 - *Confidenzialità*: ovvero la garanzia che solo le parti autorizzate possano accedere e comprendere i dati scambiati, impedendo l'accesso non autorizzato o la visualizzazione dei dati da parte di terzi.
 - *Integrità*: assicurare che i dati scambiati non siano stati alterati o compromessi durante il trasferimento, consentendo alle parti di verificare che i dati ricevuti siano identici a quelli inviati.
 - *Autenticità*: Garantire l'identità e l'affidabilità delle parti coinvolte nelle comunicazioni.
 - *Non ripudio*: garantire che le parti coinvolte nella comunicazione non possano negare l'invio o la ricezione di un determinato messaggio.

19. Conosci algoritmi di hashing nati appositamente per la crittografia e in cosa differiscono dagli algoritmi di hashing standard?

- L'hashing è il processo di trasformare dati di lunghezza variabile in una stringa di lunghezza fissa, chiamata hash value o hash code. Questo processo è deterministico, il che significa che per lo stesso input, l'output sarà sempre lo stesso.
Uno degli algoritmi che nasce appositamente per crittografare i dati è SHA-256.

20. Parlatemi degli IDS (Intrusion Detection System)

- Gli IDS analizzano eventi e producono una categoria di eventi allarmanti. Un'intrusione è un'attività tesa a compromettere la sicurezza di una risorsa. Un sistema di intrusion detection è utile alla sola identificazione dell'intrusione ma non è prevista nessun tipo di azione preventiva o di risposta ad un'intrusione. Quindi questo sistema è utile quando viene utilizzato con altri sistemi di sicurezza come può essere ad esempio un firewall, quando il blocco del firewall viene bypassato allora vi sarà IDS che potrà rilevare un accesso non consentito, inoltre un IDS può essere particolarmente utile anche per monitorare gli attacchi che provengono dall'interno della rete. Gli IDS non osservano tutto ma sono specializzati nell'analisi di particolari eventi, per effettuare tale analisi i dati provengono dal traffico di rete a vari livelli dello stack TCP/IP, dei log di sistema, di altri eventi.

L'analisi si divide in 2 modelli principali:

- Signature analysis: Comportamento basato sull'assunto che gli attacchi possono essere individuati ricercando pattern specifici o sequenze di eventi.
 - Semplice da implementare, pattern ben progettato non dà falsi positivi, correlazione immediata tra pattern ed exploit che lo definisce, il problema è che un pattern progettato male potrebbe dare falsi positivi e inoltre potrebbe essere anche causa di falsi negativi.
- Anomaly detection:
 - L'IDS analizza e impara il normale comportamento della rete o del sistema durante un periodo di tempo. Durante questa fase, il sistema acquisisce una comprensione delle normali attività, dei modelli di traffico e delle configurazioni. Sulla base delle informazioni raccolte, l'IDS costruisce profili o modelli di comportamento normale per gli utenti, i dispositivi di rete o le applicazioni. Quando si verifica un comportamento che si discosta in modo significativo dai modelli normali, l'IDS lo classifica come un'anomalia".

21. Come ci proteggiamo da un attacco MITM? Come garantiamo l'integrità di un messaggio dai MITM?

- L'attacco Man in the Middle è una tipologia di attacco nella quale l'utente malevolo riesce ad interpersi nel mezzo di una comunicazione così da riuscire ad avere accesso a tutti i messaggi che vengono scambiati e quindi rubare dati sensibili come username, password, ecc...
Uno dei metodi che possiamo utilizzare per evitare questo tipo di attacco è l'utilizzo di connessioni crittografate grazie alle quali il traffico che scambiamo non è in chiaro, inoltre, potremmo anche verificare che le chiavi pubbliche corrispondano a quelle che ci aspettiamo in modo che se il traffico fosse stato alterato ne saremmo subito a conoscenza.

22. Abbiamo due sedi aziendali distanti geograficamente e dobbiamo farle comunicare su un canale untrusted che tecnologia possiamo utilizzare per rendere la comunicazione sicura?

- Per rendere sicura una comunicazione tra due sedi distanti si può utilizzare un tunnel VPN con IPSEC e SSL/TSL.
 - Ipsec fornisce un layer di sicurezza a livello di protocollo IP, le componenti fondamentali di IPSEC sono:
 - Security Association (SA) , rappresenta l'accordo tra due entità di stabilire una connessione sicura. Ogni connessione è identificata da un SA Identifier e tali connessioni sono di tipo unidirezionale quindi per avere una comunicazione fra due host dovrò instaurare due SA. Nella SA abbiamo anche l'identificativo relativo al protocollo di sicurezza adottato che sia AH o ESP.

- Authorization Header (AH), tale header viene utilizzato per garantire l'autenticazione della sorgente e il controllo di integrità dell'intero datagram IP, non viene utilizzato per garantire la riservatezza dei dati trasmessi in una comunicazione.
- ESP: Encapsulating Security Payload, questo protocollo fornisce servizi di riservatezza cifrando il payload del pacchetto, funziona con lo scambio di chiavi simmetriche e può funzionare sia in Transport mode che in tunnel mode.

IPSEC è progettato per poter lavorare in due modalità diverse:

- Transport Mode, connessione punto-punto fra due host. Non è sempre gestibile poiché vi sono diversi apparati che non supportano questa modalità, sempre applicabile però su computer.
- Tunnel Mode, crea una connessione punto-punto fra due gateway, quindi un tunnel di comunicazione che sarà poi utilizzato per la comunicazione con i vari host delle due reti.

I vantaggi del protocollo IPSEC sono dati dal fatto che non richiede delle modifiche hardware e software dei dispositivi di rete e che rendendo le comunicazioni sicure a livello di rete rende sicure tutte le comunicazioni che viaggiano tramite protocollo IP.

23. Cosa è un attacco SQL Injection e come facciamo ad evitarli?

- Un attacco SQL Injection ha come obiettivo quello di introdurre del codice SQL all'interno di un nostro applicativo sfruttando delle falle che abbiamo creato sulle nostre pagine web. Tipicamente l'attacco avviene tramite l'inserimento di stringhe SQL in campi di input non correttamente formattati e controllati, si può quindi risalire facilmente a molte informazioni che abbiamo all'interno del DBMS o addirittura eliminare dei dati presenti per creare dei disservizi.

I metodi che possiamo utilizzare per risolvere questo problema sono diversi, dai prepared statement che sono dei metodi pre-configurati per inviare delle query al DB ed oltre a maggiore sicurezza garantiscono anche delle prestazioni migliori, un altro aspetto da considerare è sicuramente quello di inserire dei controlli all'interno dei nostri campi di input così da eliminare la possibilità di inserire tutti quei caratteri che possono essere confusi per sintassi di SQL come gli apici o il carattere *.

24. Che cos'è il DDoS? Come facciamo ad evitarlo?

- DDoS che è la sigla di Distributed Denial of Service è un tipo di attacco che mira a congestionare un sistema inviando una quantità di dati troppo grande per essere gestita. Il concetto alla base è quello del bandwidth consumption, ovvero esaurire tutta la banda disponibile per un sistema. Attualmente l'attacco più grande che ci è stato nell'ordine dei 4 TB/s.

Questo tipo di attacco di solito si avvale di una *BOTNET*, una botnet è una rete di computer zombie che vengono controllati da un master il quale a un certo punto, tipicamente quando la grandezza della rete soddisfa determinati requisiti, deciderà di far partire l'attacco verso i sistemi dell'attaccato.

Il grande problema di questi attacchi è che non sono gestibili dall'utente finale ed infatti l'unico a poter fare qualcosa è il nostro ISP utilizzando ad esempio dei filtri geografici, utilizzo di CDN, o utilizzo di altri strumenti a livello di ISP.

25. Natting e Patting

- Il NAT è una tecnica con il quale un router si interpone tra la rete esterna e una rete interna, tipicamente aziendale. L'obiettivo del natting è quello di rendere invisibili gli host della rete interna alla rete esterna e per farlo utilizza una mappatura degli indirizzi IP. Il suo funzionamento si basa su delle tabelle che effettuano una traduzione degli indirizzi IP, in questo modo un host esterno comunicherà solo con NAT Router che poi si occuperà di smistare correttamente i pacchetti all'host interessato.

In una versione del natting, è prevista anche la possibilità di "tradurre" non solo l'indirizzo IP sorgente, ma anche la porta sorgente, il cosiddetto PATTING.

26. Un malware moderno crea dei certificati falsi per autovalidarsi, come fa?

- Un malware moderno potrebbe tentare di creare dei certificati autofirmati che ovviamente non sono generati da una Certification Authority ma che però potrebbero risultare validi ad un utente poco attento, in alternativa alcuni malware potrebbero tentare di rubare dei certificati esistenti sulla macchina host infettata accedendo al repository dei certificati installati estraendoli per poi riutilizzarli.

27. Come possiamo evitare un exfiltration di dati dalla nostra azienda?

- Per prevenire l'uscita dei dati dalla nostra azienda dobbiamo introdurre diverse tecniche, innanzitutto sarebbe molto importante classificare i dati a seconda della loro importanza dopodiché eseguire dei rigidi controlli sugli accessi ad esempio si potrebbe pensare di inserire un firewall per controllare il traffico che dall'esterno arriva all'interno della nostra azienda, e per monitorare il traffico che esce dalla nostra azienda si potrebbe pensare di utilizzare un DLP (Data Loss Prevention).
 - **DLP** è un insieme di tecniche e tecnologie che fa riferimento a tecniche e sistemi che identificano, monitorano e proteggono i dati all'interno di un contesto aziendale. Per far sì che funzioni un sistema DLP ha bisogno di policy chiare che permettano di capire quando un utente o un sistema sta trattando dei dati in modo incorretto.

28. Come si fa a negoziare una chiave simmetrica?

- Uno dei protocolli più utilizzati per lo scambio di una chiave simmetrica è quello di Diffie-Hellman il quale si basa su un sistema di "chiave pubblica" che verrà utilizzata per generare la chiave privata degli utenti. Di base questo sistema, come anche gli altri come IKE (Internet Key Exchange) e TLS (Transport Layer Security) hanno come obiettivo quello di stabilire una chiave segreta condivisa tra le due parti comunicanti in modo sicuro.

29. Parla del buffer overflow

- Permette ad un attaccante di inserire un volume di dati superiore alla dimensione prestabilita e riversare i dati in eccesso nello stack, sovrascrivendo l'istruzione pointer che potrebbe puntare ad un programma (tipicamente uno Shellcode) opportunamente creato per compiere effetti indesiderati.

Vi sono diversi tipi di buffer overflow:

- **Stack segment:** Si va ad inserire un numero di dati maggiore rispetto a quello atteso dal buffer in questo modo si va a modificare l'indirizzo di ritorno dell'Instruction Pointer, questa modifica può avere due effetti:
 - Puntamento ad un'area di memoria non scrivibile dal processo e quindi Segmentation Fault.
 - Puntamento ad un'area di memoria scrivibile dal processo e quindi malfunzionamento del programma. Questo malfunzionamento potrebbe essere utilizzato per far puntare il programma ad una parte di codice inserita

dall'utente malevolo (BYTECODE INJECTION) tipicamente una shellcode tramite la quale l'attaccante può ottenere il controllo della macchina da remoto.

Uno dei migliori metodi per proteggersi è quello di non rendere possibile l'esecuzione di codice direttamente dallo stack segment.

Un altro tipo di attacco è quello relativo all'EXPLOIT, questo attacco si basa sulla modifica degli indirizzi di memoria all'interno delle istruzioni JMP e CALL facendo puntare l'IP ad una funzione bin/sh che permette quindi l'avvio di una shell.

30. Come funziona la posta elettronica sicura? Come funziona S/MIME?

- Il protocollo STMP sul quale si basa la posta elettronica non è un sistema sicuro poiché è in chiaro e non richiede autenticazione, infatti interagendo con un server STMP è possibile inviare dei messaggi di posta con mittenti falsi. Per mitigare questa situazione sono stati creati dei nuovi protocolli che permettono di rendere più sicura la posta elettronica, in particolare S/MIME: è un protocollo che permette lo scambio di messaggi testuali che si basa sul protocollo MIME il applica una estensione agli header per gestire file multimediali ed altri tipi di dato oltre al semplice testo. Il protocollo S/MIME che baal semplice testo. Il protocollo S/MIME che basa il suo concetto di sicurezza sullo scambio di certificati forniti da CA e crittografia (RSA) per rendere illegibile il messaggio trasmesso.

31. Dove possiamo utilizzare la crittografia asimmetrica?

- La crittografia asimmetrica, o crittografia a chiave pubblica, è utilizzata per diverse finalità nella sicurezza informatica. Essa consente lo scambio sicuro di chiavi segrete, l'autenticazione e l'autorizzazione degli utenti, la creazione di firme digitali per garantire l'integrità dei messaggi e la gestione delle crittovalute. È ampiamente impiegata nei protocolli di comunicazione sicura, come SSL/TLS, per stabilire canali crittografati tra client e server su Internet. Inoltre, svolge un ruolo fondamentale nell'implementazione di autenticazione forte e controllo degli accessi. Grazie alla sua natura a doppia chiave, offre una robusta soluzione per risolvere sfide di sicurezza, come lo scambio sicuro di informazioni su reti non protette.

32. In quali protocolli viene utilizzata la crittografia simmetrica?

- La crittografia simmetrica, che impiega una singola chiave per cifrare e decifrare i dati, è utilizzata in una vasta gamma di protocolli e tecnologie. Tra i più comuni vi sono SSL/TLS per la sicurezza delle comunicazioni su Internet, IPsec per la sicurezza delle reti private virtuali (VPN), SSH per l'accesso remoto sicuro ai sistemi, PGP/GPG per la crittografia delle email e la protezione dei dati archiviati tramite algoritmi come AES, DES e 3DES. La crittografia simmetrica è apprezzata per la sua efficienza e velocità di elaborazione, risultando fondamentale in molte applicazioni di sicurezza informatica.

33. L'autentication header perchè garantisce l'autenticazione?

- L'AH autentica l'intero pacchetto IP, incluso l'header IP e i dati del payload attraverso un hash crittografico calcolato utilizzando l'algoritmo di autenticazione crittografica selezionato. Questo significa che qualsiasi modificazione apportata ai dati durante la trasmissione viene rilevata tramite il calcolo dell'hash. Inoltre, l'AH protegge anche l'header IP da alterazioni.

34. Che cos'è un HMAC?

- Un HMAC (Hash-based Message Authentication Code) è un codice di autenticazione del messaggio basato sull'hash, utilizzato per verificare l'integrità e l'autenticità dei dati trasmessi su una rete. È una costruzione crittografica che combina una funzione di hash crittografica con una chiave segreta. L'HMAC viene calcolato tramite una combinazione di dati di input e una chiave segreta utilizzando una funzione di hash crittografica, come SHA-256

35. Cos'è e come funziona PGP?

- Il protocollo PGP viene utilizzato nel contesto della sicurezza per la posta elettronica. Il concetto base del suo funzionamento è relativo al Web of Trust, PGP applica un algoritmo di Hashing per generare l'hash del messaggio. Gli utenti generano una coppia di chiavi: una chiave pubblica e una chiave privata, quando un utente vuole inviare un messaggio crittografato a un altro utente, utilizza la chiave pubblica del destinatario per crittografare il messaggio, per firmare digitalmente un messaggio, l'utente utilizza la propria chiave privata per generare una firma digitale. La firma viene allegata al messaggio e può essere verificata utilizzando la chiave pubblica del mittente. Quando si crittografa un messaggio con PGP, viene generata una chiave di **sessione casuale**, detta chiave simmetrica. Questa chiave simmetrica viene quindi crittografata utilizzando la chiave pubblica del destinatario e inviata insieme al messaggio crittografato, quando il destinatario riceve il messaggio crittografato, utilizza la propria chiave privata per decrittografare la chiave simmetrica. Quindi, utilizza questa chiave simmetrica per decrittografare il contenuto del messaggio.

36. Quali tecnologie possono ridurre o limitare gli attacchi spear fishing?

- Un attacco di spear phishing è una forma mirata di phishing in cui gli aggressori inviano e-mail fraudolente, spesso personalizzate e apparentemente provenienti da fonti attendibili, a singoli individui o a gruppi specifici all'interno di un'organizzazione. L'obiettivo è ingannare le vittime per ottenere informazioni sensibili, credenziali di accesso o per indurle a compiere azioni dannose come il download di malware.

Per mitigare gli attacchi di spear phishing, le organizzazioni possono adottare diverse misure preventive. Prima di tutto, è essenziale condurre regolarmente programmi di formazione sulla sicurezza informatica per educare gli utenti sui rischi del phishing e insegnare loro come riconoscere le e-mail sospette. Inoltre, l'implementazione di filtri antispam e antiphishing avanzati può aiutare a bloccare le e-mail fraudolente prima che raggiungano le caselle di posta degli utenti.

L'autenticazione a due fattori (2FA) può essere utilizzata per aggiungere un ulteriore strato di protezione, richiedendo ai dipendenti di autenticarsi tramite un secondo metodo (come un token o un'applicazione mobile) oltre alle credenziali di accesso standard.

37. Quali sono i modi e i possibili problemi per negoziare una chiave asimmetrica?

- La negoziazione di chiavi asimmetriche è fondamentale per stabilire una comunicazione sicura tra due entità. Vediamo come funzionano i principali algoritmi:
 - Diffie-Hellman:
 - Le due parti concordano su parametri pubblici (base e modulo) e generano segretamente le proprie chiavi private. Successivamente, scambiano solo le informazioni pubbliche per generare in modo indipendente la chiave segreta condivisa.
 - Problemi Potenziali: Un attaccante può condurre un attacco di tipo "man-in-the-middle" cercando di intercettare e manipolare gli scambi di chiavi. Questo rischio può essere mitigato attraverso la firma digitale o l'uso di canali sicuri.
 - RSA:
 - Funzionamento: Una parte genera una coppia di chiavi pubblica e privata. La chiave pubblica è condivisa con l'altra parte, che la utilizza per cifrare i dati. Solo chi possiede la chiave privata associata può decifrare il messaggio cifrato.
 - Problemi Potenziali: Se l'algoritmo RSA non fosse implementato correttamente, potrebbe essere vulnerabile a attacchi di fattorizzazione. Inoltre, la sicurezza dipende dalla protezione della chiave privata. Gli attacchi di fattorizzazione si riferiscono al processo di scomposizione di un numero intero in fattori primi, nel caso dell'algoritmo RSA, la sicurezza si basa sulla difficoltà computazionale di fattorizzare grandi numeri primi. Se un'entità potesse fattorizzare il modulo RSA (il prodotto di due numeri primi molto grandi) in modo efficiente, potrebbe ottenere la chiave privata e decifrare i messaggi cifrati con la chiave pubblica corrispondente.

38. Quali sono i modi e i possibili problemi per negoziare una chiave simmetrica?

- La negoziazione di una chiave simmetrica può avvenire attraverso diversi metodi e protocolli.
 - Scambio di chiavi fuori dal canale di comunicazione principale, ad esempio per telefono o di persona.
 - Scambio di chiavi tramite crittografia asimmetrica, una delle parti genera una chiave simmetrica, la cifra con la chiave pubblica della controparte e la invia. Solo il destinatario può decifrare la chiave simmetrica utilizzando la propria chiave privata.

I problemi possono derivare dalla scarsa sicurezza dei canali di comunicazione, dello storage sbagliato delle chiavi o ancora per attacchi di tipo man in the middle.

39. Che cos'è una DMZ e con quali tecnologie si realizza?

- Una De-Militarized zone è una porzione di rete che non fa parte né della rete interna né della rete esterna, consente di minimizzare l'esposizione alla rete esterna consentendo l'accesso dall'esterno solo alle macchine della DMZ. Normalmente in DMZ si posizionano i server che devono offrire dei servizi pubblici di rete. Di solito nella dmz inserisco quei servizi che sono più esposti ad attacchi. Uno dei metodi migliori per la sua realizzazione è **Dual Firewall (Screened Subnet)**, questa configurazione prevede l'uso di due firewall: uno tra la rete interna e la DMZ e l'altro tra la DMZ e Internet. Questo offre un livello aggiuntivo di sicurezza, impedendo agli attaccanti di passare direttamente dalla DMZ alla rete interna.

40. Che cos'è il bastion host?

- Un bastion host è un server configurato e protetto per essere l'unico punto di accesso tra una rete interna sicura e una rete esterna non attendibile, come Internet. Questo server è appositamente configurato per fornire un livello aggiuntivo di sicurezza alla rete interna, limitando l'accesso e monitorando attentamente il traffico in entrata e in uscita. Tipicamente, un bastion host è configurato con un insieme ridotto di servizi e funzionalità, limitando le porte aperte e utilizzando tecniche come l'accesso remoto sicuro (SSH) per consentire l'accesso solo agli amministratori autorizzati. Può anche essere configurato con strumenti di logging e monitoraggio avanzati per rilevare e rispondere prontamente alle minacce.

41. Parlatemi della cifratura a flusso? Perché è simile al one time pad?

- La cifratura a flusso cerca di emulare il comportamento di un flusso casuale di bit, rendendo estremamente difficile per un attaccante predire il prossimo bit nella sequenza. Questo metodo è simile a una chiave simmetrica, ma anziché generare una sequenza di chiavi statica, genera una sequenza che sembra casuale e non ripetitiva. Il one-time pad è un sistema di cifratura a flusso in cui la chiave crittografica è lunga quanto il messaggio stesso e viene utilizzata solo una volta. La cifratura a flusso e il one-time pad sono correlati nel senso che entrambi utilizzano flussi di bit casuali per cifrare i dati, ma la cifratura a flusso cerca di fornire un'alternativa pratica al one-time pad per applicazioni reali, dato che l'implementazione del one-time-pad è troppo onerosa.

42. Che ruolo ha la cifratura asimmetrica nel traffico https?

- Nel traffico HTTPS, la cifratura asimmetrica svolge un ruolo vitale. Durante l'handshake SSL/TLS, il server invia al client un certificato contenente la sua chiave pubblica. Il client usa questa chiave per scambiare una chiave di sessione crittografata. Questa chiave di sessione viene utilizzata per cifrare e decifrare i dati durante la sessione HTTPS, garantendo confidenzialità e integrità. Il certificato del server viene verificato da un'autorità di certificazione di fiducia, assicurando l'autenticità del server. La crittografia asimmetrica rende possibile lo scambio sicuro di chiavi, l'autenticazione del server e la creazione di una connessione sicura tra client e server, proteggendo i dati trasmessi.

43. Che cosa è una firma digitale? E quando ha o deve avere valore legale?

- Una firma digitale è un metodo crittografico che fornisce un meccanismo per verificare l'autenticità e l'integrità di un documento digitale o un messaggio. Viene creata applicando un algoritmo di hash al documento e quindi cifrando l'hash risultante con la chiave privata del firmatario. Chiunque abbia la chiave pubblica del firmatario può verificare la firma decifrando l'hash cifrato e confrontandolo con un nuovo hash calcolato per il documento. Le firme digitali possono avere valore legale in diversi contesti, come contratti online, transazioni finanziarie, documenti legali e comunicazioni ufficiali.

44. Quali sono le funzionalità dei firewall più avanzati? Che attacchi potrebbero rilevare rispetto a quelli tradizionali?

- I firewall avanzati possono rilevare e mitigare una vasta gamma di attacchi informatici, inclusi quelli tradizionali e quelli più sofisticati. Come attacchi di malware, attacchi DDoS, Spoofing, Ransomware, Phishing per farlo utilizzano tecnologie come il DPI, Application Layer Filtering, IDPS, VPN, ecc..

45. In un contesto dove il traffico è sempre cifrato, un IDS può essere ancora utile o dobbiamo buttarlo via?

- Anche in un contesto dove abbiamo sempre traffico cifrato un IDS può ancora risultare utile, ad esempio potrebbe essere utilizzato per valutare i metadati dei pacchetti, il rilevamento delle firme ovvero di pattern o firme di noti per riconoscere un attacco, analisi del comportamento.

46. Quali sono gli aspetti dei log importanti per la forensics?

- Possiamo far riferimento a vari campi dei log come timestamp, indirizzi IP e nomi degli host, tipi di evento come login, tentativi di accesso falliti, modifiche a file di configurazione, ecc..

47. Cross Site Scripting (XSS)

- Sono delle vulnerabilità relative a linguaggi di scripting front-end come ad esempio Javascript, la diffusione del virus può avvenire tramite URL in una mail, in un messaggio sui social network ecc....

Vi sono due tipi di attacco XSS:

- *Reflected*: l'input malevolo proveniente dall'utente viene utilizzato senza verifica da uno script del server per generare una pagina dinamica e restituita allo stesso browser che ha fatto la richiesta.
Quindi posso iniettare del codice javascript nel campo di input, e il browser mi restituirà l'esecuzione del codice che ho iniettato.
Quindi l'utente tramite phishing o tecniche di social engineering invia il link ad un utente, tale URL contiene il codice malevolo che sarà eseguito all'accesso sul sito web.
- *Stored*: tramite questo attacco l'utente malevolo riesce a spargere varie minacce all'interno di un sito web, l'utente vittima entra nel sito compromesso, quando l'utente inciampa in una "mina" XSS esso viene attaccato, ad esempio venendo costretto a riefettuare il login così che l'utente malevolo si appropria delle credenziali di accesso.